UNIVERSIDAD COMPLUTENSE MADRID

ntic master

TAREA EVALUABLE

Máster en Ciberseguridad

MÓDULO

Introducción a las Infraestructuras Críticas

PROFESOR

D. Francisco Martín Vázquez

INDEX

1. Evaluación Conceptos Introducción a Infraestructuras Críticas.....3
1.1. Introducción.....3
1.2. Punto evaluable 1: Análisis simplificado de riesgos.....3
1.3. Punto evaluable 2: Posibles consecuencias de los riesgos identificados.....3
1.4. Punto evaluable 3: Propuesta de medidas de mitigación para los riesgos identificados..3
1.5. Punto evaluable 4: Simulación ataque Sistemas SCADA/ICS: Descripción del Escenario propuesto.....4
1.6. Punto evaluable 5: Simulación ataque Sistemas SCADA/ICS: Lectura de Registros/Coils.....4
1.7. Punto evaluable 6: Simulación ataque Sistemas SCADA/ICS: Modificación de Registros/Coils.....5
1.8. Punto evaluable 7: Propuestas de mitigación de las vulnerabilidades explotadas.....5
1.9. Cómo entregar la tarea.....5

1. Evaluación Conceptos Introducción a Infraestructuras Críticas

1.1. Introducción

En la primera parte de la tarea, los estudiantes realizarán un análisis simplificado de riesgos sobre una planta de tratamiento de aguas en España, identificando las vulnerabilidades cibernéticas y físicas, las amenazas asociadas y las posibles consecuencias.

En la segunda parte de la tarea, supongamos que la planta de tratamiento de aguas descrita utiliza PLCs con protocolo MODBUS. El alumno deberá realizar una simulación controlada de un ataque a un sistema SCADA/ICS (MODBUS) utilizando herramientas como Wireshark, Metasploit o Modbus Simulator, QModMaster o ModbusPal (El alumno podrá consultar como referencia el documento “Práctica MODBUS”). El alumno debe identificar las vulnerabilidades explotadas y proponer contramedidas específicas. Para la realización de la práctica, el alumno deberá incluir un esquema de red simplificado, direccionamiento IP, configuración del maestro y el esclavo MODBUS TCP (coils y Registros, basta con 10 coils y 10 registros como ejemplo), comandos ejecutados en Metasploit y capturas de pantalla como evidencia del éxito del ataque (PoC). El alumno debe identificar las vulnerabilidades explotadas y proponer contramedidas específicas.

1.2. Punto evaluable 1: Análisis simplificado de riesgos

Valor: +2 puntos

El alumno deberá de aplicar marcos de trabajo como el *MAGERIT* o el *NIST Risk Management Framework* para la realización de un análisis simplificado de riesgos, explicando en cada caso cuál ha sido el criterio utilizado para la evaluación del riesgo y la identificación de amenazas. Bastará con un listado simple, incluyendo una breve explicación, así como la valoración final del riesgo identificado en base al tipo de infraestructura y otros factores.

1.3. Punto evaluable 2: Posibles consecuencias de los riesgos identificados

Valor: +1,5 puntos

El alumno deberá de explicar brevemente las posibles consecuencias que tendría la materialización de los riesgos identificados, tanto a nivel operativo como en otros operadores o la propia sociedad.

1.4. Punto evaluable 3: Propuesta de medidas de mitigación para los riesgos identificados.

Valor: +1 puntos

El alumno deberá proponer una serie de medidas para mitigar los riesgos identificados en el apartado anterior. Para cada medida de mitigación incluida, el alumno incluirá una breve descripción de cómo se mitiga el riesgo.

1.5. Punto evaluable 4: Simulación ataque Sistemas SCADA/ICS: Descripción del Escenario propuesto

Valor: +2 puntos

El alumno deberá incluir un esquema gráfico de red simplificado (draw.io o similar), direccionamiento IP utilizado para el esclavo, el maestro y el atacante, software utilizado y configuración del maestro y el esclavo MODBUS TCP (coils y Registros, basta con 10 coils y 10 registros como ejemplo.

NOTA IMPORTANTE: Para el direccionamiento IP del escenario de simulación, el alumno deberá utilizar una red IP clase B privada del tipo 172.16.X.0/24. Donde X será un valor entre 0 y 255 pero que deberá ser el valor resultante de realizar la operación de los últimos 3 dígitos del DNI MOD 255. Por ejemplo, si un alumno tiene el DNI: 50506634, X tomará el valor: (634 MOD 255) = 124.

Por tanto, el alumno usará la red: 172.16.124.0/24 para su escenario

1.6. Punto evaluable 5: Simulación ataque Sistemas SCADA/ICS: Lectura de Registros/Coils.

Valor: +1,5 puntos

El alumno lanzará un ataque desde el equipo atacante (Kali Linux o similar) para obtener el estado de los registros del PLC Esclavo y realizará una descripción de las herramientas utilizadas, comandos ejecutados en Metasploit y capturas de pantalla como evidencia del éxito del ataque (PoC). Indicar cual es la vulnerabilidad del protocolo que permite este tipo de ataque.

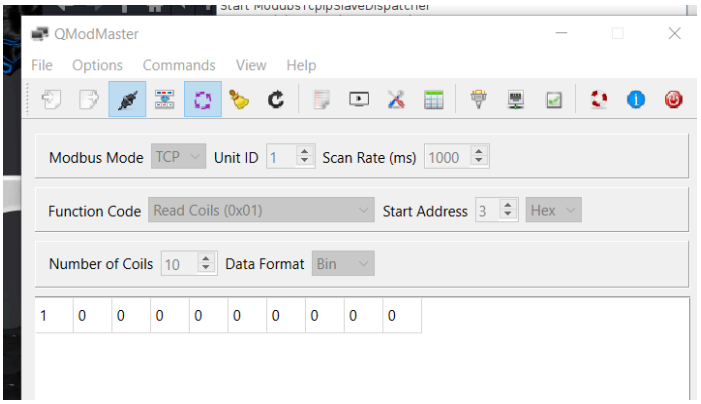

Ilustración 1. Ejemplo estado PLC

1.7. Punto evaluable 6: Simulación ataque Sistemas SCADA/ICS: Modificación de Registros/Coils.

Valor: +1 puntos

El alumno lanzará un ataque desde el equipo atacante (Kali Linux o similar) para obtener el estado de los registros del PLC Esclavo y realizará una descripción de las herramientas utilizadas, comandos ejecutados en Metasploit y capturas de pantalla como evidencia del éxito del ataque (PoC). Indicar cual es la vulnerabilidad del protocolo que permite este tipo de ataque.

1.8. Punto evaluable 7: Propuestas de mitigación de las vulnerabilidades explotadas

Valor: +1 puntos

El alumno deberá proponer medidas de mitigación para el escenario descrito y las vulnerabilidades explotadas. Enumerará las vulnerabilidades identificadas y explotadas y las medidas de mitigación que considere oportunas para mitigar el riesgo hasta niveles aceptables.

1.9. Cómo entregar la tarea

El alumno deberá subir su tarea con las respuestas de cada uno de los puntos evaluables indicados (del 1 al 7) en documento con formato MS Word o similar (documento de texto con imágenes), incluyendo la respuesta de cada uno de los puntos, incluyendo las imágenes que el alumno considere, con el siguiente patrón en el nombre del archivo:

TAREA_IICC_DNI_NOMBRE_APELLIDO1_APELLIDO2.docx

Cualquier duda o incidencia con la entrega se puede consultar directamente con el profesor a través del foro y chat del Campus de la Universidad.